Chapter 1: Malware Analysis Primer

→ Tạo nền tảng về một tiến trình chung và các phương pháp của việc phân tích Malware.

Malware Analysis Là gì?

- Bất cứ một phần mềm mà gây tổn hại tới người dùng ,máy tính, hoặc mạng máy tính có thể được coi là một malware, bao gồm viruses, trojan, worms, rootkits, scareware, spyware.
- Malware Analysis đề cập tới việc "mổ xẻ" một malware để hiểu các nó hoạt động, cách phát hiện và làm thế nào để đánh bại và loại bỏ chúng.

http://www.practicalmalwareanalysis.com/

Mục Đích

- Mục đích của một Malware Analysis là cung cấp thông tin mà mình cần để đáp lại một cuộc xâm nhập.
- Xác định rõ ràng điều gì đã xảy ra.
- Đảm bảo rằng mình đã tìm được tất cả các machines, files bị nhiễm. (Infected)
- Khi phân tích một malware tiềm ẩn thì phải xác định khả năng của nó, làm thế nào để phát hiện nó ở trong mạng, và làm thế nào để đo/ phòng chưa rủi ro của nó.

→ Một khi đã tìm ra file cần phân tích, việc của mình là tạo ra các chữ ký (signature) để phát hiện các sự lây nhiễm malware trong mạng của mình.

Host-based signatures

- Host-based signatures, hoặc indicators được dùng để tìm ra các code nguy hại trên máy của nạn nhân. Thường sẽ tìm ra các file được tạo/ thay đổi bởi malware (hoặc các thay đổi cụ thể mà nó tạo lên trên cơ sở dữ liệu)
- Nó tập trugn vào những thứ mà con malware có thể làm, không phải là đặc tính của con malware.

Network Signatures

- Tương tự, Network Signatures được sử dụng để phát hiện malicious code bởi việc giám sát network traffic.
- Network Signatures có thể được tạo ra mà không cần malware analysis, nhưng khi được tạo bởi malware analysis sẽ hiệu quả hơn.

→ Sau khi đã có signatures, mình cần tìm hiểu các malware hoạt động.

Malware Analysis Techniques

Có 2 phương pháp tiếp cận chính cho Malware Analysis: Tĩnh (static) và Động (Dynamic). Mỗi phương pháp đều có các cách cơ bản và nâng cao.

- Static bao gồm xem xét malware mà không chạy nó
- Dynamic thì ngược lại, có chạy malware.

1. Basic Static Analysis

- Phương pháp phân tích tĩnh đơn giản bao gồm việc xem xét (kiểm tra thông tin và cấu trúc biên ngoài) file exe mà không nhìn vào các instruction (? program's compiled machine code) của nó.
    - **File Hash:** Các mã băm (MD5, SHA-1, SHA-256) để nhận dạng file.
    - **Strings:** Các chuỗi ký tự có thể đọc được (ASCII/Unicode) nằm trong file (ví dụ: địa chỉ IP, URL, tên file, registry keys).
    - **Thông tin Header (PE Header):** Thư viện liên kết (Imports), các hàm xuất (Exports), các phân vùng (Sections), và thời gian biên dịch.

    - **Định dạng file:** Chữ ký file (Magic bytes) để xác định loại file thực sự.
    - **Metadata & Resources:** Thông tin phiên bản, chứng chỉ số (Digital certificates), icon, hoặc các file được nhúng kèm.
    - **Packers/Obfuscators:** Dấu hiệu cho thấy file đã bị nén hoặc làm rối mã để qua mặt phần mềm diệt virus.
- Phương pháp này có thể giúp dám chắc xem file này có malicious hay không, cung cấp thông tin về chức năng của nó. (thi thoảng giúp tạo các network signatures cơ bản)
- Phương pháp này nhanh nhưng không hiệu quả với các file phức tạp hơn.

2. Basic Dynamic Analysis

- Bao gồm việc chạy và quan sát hoạt động của nó ở trong hệ thông để loại bỏ infection, tạo ra các signatures hiệu quả.
    - **Network:** Tìm các địa chỉ IP, tên miền (C&C server) mà malware kết nối đến.
    - **File System:** Ghi nhận các file mới được tạo (dropped files) hoặc bị thay đổi.
    - **Registry:** Xác định các khóa registry được thêm vào để malware tự khởi động cùng Windows (Persistence).
    - **Process:** Xem malware có tạo tiến trình con hay tiêm mã (inject) vào tiến trình hệ thống hợp lệ không.
- Cần phải tạo một môi trường an toàn trước khi chạy malware ấy.
- Phương pháp này nhanh nhưng không hiệu quả với các file phức tạp hơn.

3. Advanced Static Analysis

- Bao gồm reverse-engineering phần bên trong của malware bằng cách cho exe ấy vào một disassembler (trình dịch ngược - kiểu chuyển lại thành assembly?) và nhìn vào các instructions để tìm ra nó làm gì.
    - Có thể hiểu chính xác luồng logic, cách malware thao tác với bộ nhớ, các thuật toán mã hóa được sử dụng và các hàm API hệ thống mà nó gọi để

thực thi ý đồ xấu, tất cả mà không cần phải cho nó chạy.

- Advanced Static Analysis đòi hỏi kiến thức về disassembly, code constructs, và các khái niệm về hệ điều hành Windows.

4. Advanced Dynamic Analysis

- Bao gồm việc sử dụng một debugger để kiểm tra trang thái bên trong của một file exe malicious đang chạy. (không hiểu lắm)
- Đây là phương pháp tốt để lấy được thông tin khi mà các phương pháp khác không hiệu quả

Types of Malware

1. Backdoor: Là Malicious code có hại, được tự cái vào một máy, giúp người tấn công có thể truy cập mà không cần authentication, và chạy các lệnh ở trong hệ local systems.
2. Botnet: Giống backdoor, nhưng tất cả các máy bị nhiễm bởi một botnet sẽ nhận được các lệnh tương tự nhau từ một command-and-control server.
3. Downloader: Là Malicicous code tồn tại chỉ để tải về các Malicious code khác. Thường được sử dụng khi người tấn công mới truy cập được hệ thống.
4. Information-stealing malware: Thu thập thông tin của máy nạn nhân và gửi tới người tấn công. Thường được sử dụng để cướp tài khoản trên mạng (email, ebanking). VD: Sniffers (nghe lén gói tin mạng), Password hash grabbers (trộm hash của mật khẩu), Keyloggers.
5. Launcher: Chương trình được sử dụng để chạy các Malicious Programs khác. Launcher sử dụng các phương pháp không truyền thống để thực hiện điều này.
6. Rootkit: Được thiết kế để che giấu sự tồn tại của các code khác. Rootkits được kết hợp với các malware khác (backdoor, ...) để attacker có thể remote access và khiến code khó phát hiện.

7. Scareware: Malware dùng để doạ nạn nhân để mua một cái gì đó. Kiểu “máy tính bạn bị nhiễm virus và các duy nhất để loại bỏ là mua phần mềm của chúng tôi” (phần mềm đó chỉ đơn giản là loại bỏ scareware ấy đi)
8. Spam-sending malware: Khiến máy của nạn nhân gửi spam. Malware này giúp attacker bán dịch vụ gửi spam (spam-sending services)
9. Worm or virus: Malicious code mà có thể tự copy chính nó và lây nhiễm các máy tính khác.

- Malware còn có thể được phân loại dựa trên mục đích tấn công lớn (mass) hay tập trung (targeted).
    - Mass malware (như scareware) thường được thiết kế để lây nhiễm nhiều máy nhất có thể. Cách này ít phức tạp, dễ phát hiện và bảo vệ hơn.
    - Tảgeted malware thường nhắm tới một tổ chức cụ thể. Nó không phổ biến và thường hệ thống của mình sẽ không thể bảo vệ khỏi nó. Đòi hỏi analysis chi tiết và phức tạp.

General Rules for Malare Analysis

Các quy tắc chung cho Malware Analysis

1. Không nên quá tập chung vào tiểu tiết. Nên tập chung vào các yếu tố chính, và nếu trong các phần quá phức tạp thì nên có một cái nhìn tổng quát.
2. Nhỡ rằng có các công cụ khác nhau cho các cách thức khác nhau. Tất nhiên các công cụ sẽ có thể trùng lặp nhưng có thể thử tiếp cận malware từ các khía cạnh khác.
3. Malware Analysis giống như mèo đuổi chuột. Có thể sẽ có các cách phân tích malware mới nhưng sẽ được đáp lại bằng các cách ngăn chặn mới. Mình phải có khả năng nhận ra, hiểu, và ứng phó.